OPERATION CHIMERA — DIGITAL FORENSICS & INCIDENT RESPONSE (DFIR)

Organization: PT Vinix Seven Aurum

Program: Cybersecurity Ethical Hacker

Role: SOC Analyst & Digital Forensics Responder

Lead Mentor: Bagus Sudung Prakoso

Kelompok 8 :

- Afnan Yazid Pradana
- Kelvin Febrianto
- Kurniawan Saputra
- Rishfan Mailizar
- Robin Felix Hama

Cybersecurity Ethical Hacker

1. INCIDENT SCENARIO

On **October 30, 2026**, security monitoring alerted on anomalous activity targeting the **Internal HR Portal (hr-portal.vinix.local)** of PT Vinix Seven Aurum. The threat actor gained initial access through the web application, escalated privileges to root, embedded covert data into a system backup artifact, and modified filesystem timestamps to hinder forensic timeline reconstruction.

Four primary forensic artifacts have been acquired from the compromised host and placed inside the evidence/ directory. Your objective is to perform forensic triage using **forensic_triage.py** and document all findings comprehensively in the **IR_Playbook_Chimera.md**.

2. PROVIDED FILES

You are provided with a toolkit and an evidence package. Ensure you do not modify the original evidence files.

- **forensic_triage.py** — Automated DFIR triage and anomaly scanner. • **IR_Playbook_Chimera.md** — Incident Response report template (to be completed and submitted).
- **evidence/** — Directory containing the acquired forensic artifacts:
    - evidence/hr_portal.log

o evidence/chimera_memo.wav

o evidence/auth_cookie_audit.py

o evidence/backup_manager.c

3. ASSESSMENT TASKS (DFIR WORKFLOW)

Task 1: Evidence Integrity & Chain of Custody (Section 2) Calculate the SHA-256 hash, file size, and inode number for all four artifacts in the evidence/ directory using the command python3 forensic_triage.py --hash <filepath>. Record the exact output results in Section 2.1 of your IR Playbook.

```
┌──(kurniawan㉿Kurniawan)-[~/Operation_Chimera]
└─$ ls
Operation_Chimera_Student_Pack.zip

┌──(kurniawan㉿Kurniawan)-[~/Operation_Chimera]
└─$ unzip Operation_Chimera_Student_Pack.zip
Archive:  Operation_Chimera_Student_Pack.zip
warning:  Operation_Chimera_Student_Pack.zip appears to use backslashes as path separators
  inflating: evidence/auth_cookie_audit.py
  inflating: evidence/backup_manager.c
  inflating: evidence/chimera_memo.wav
  inflating: evidence/hr_portal.log
  inflating: forensic_triage.py
  inflating: IR_Playbook_Chimera.md
```

```
┌──(kurniawan㉿Kurniawan)-[~/Operation_Chimera]
└─$ chmod +x forensic_triage.py
```

```
┌──(kurniawan㉿Kurniawan)-[~/Operation_Chimera]
└─$ ls -la
total 36
drwxrwxr-x  3 kurniawan kurniawan 4096 Nov  6 20:41 .
drwx------ 22 kurniawan kurniawan 4096 Nov  6 20:36 ..
drwxrwxr-x  2 kurniawan kurniawan 4096 Nov  6 20:41 evidence
-rwxrwxr-x  1 kurniawan kurniawan 9524 Nov  3 12:24 forensic_triage.py
-rw-rw-r--  1 kurniawan kurniawan 2870 Nov  3 12:25 IR_Playbook_Chimera.md
-rwxrw-rw-  1 kurniawan kurniawan 6545 Nov  5 19:23 Operation_Chimera_Student_Pack.zip
```

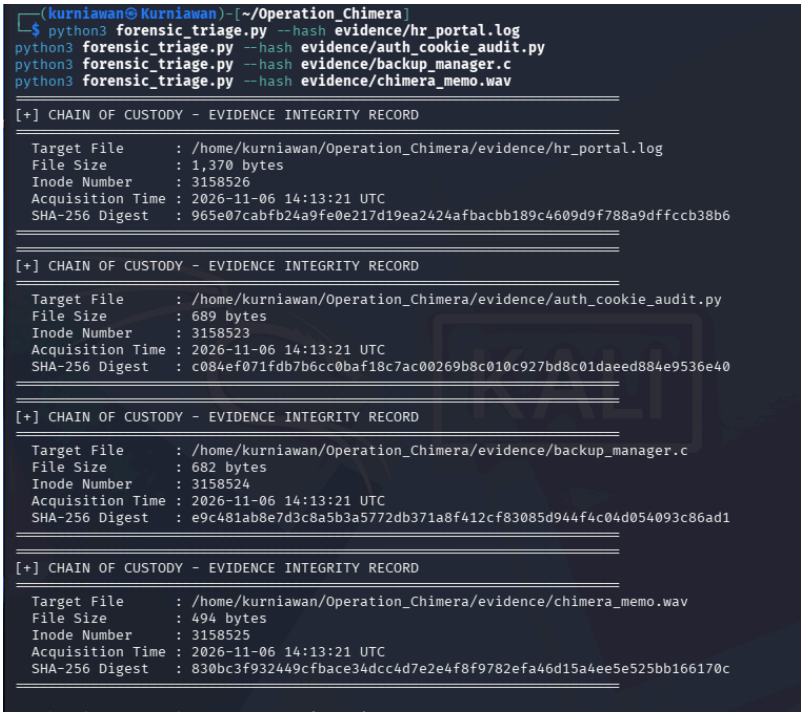
```
┌──(kurniawan㉿Kurniawan)-[~/Operation_Chimera]
└─$ ls -la evidence/
total 24
drwxrwxr-x 2 kurniawan kurniawan 4096 Nov  6 20:41 .
drwxrwxr-x 3 kurniawan kurniawan 4096 Nov  6 20:41 ..
-rw-rw-r-- 1 kurniawan kurniawan  689 Nov  3 12:26 auth_cookie_audit.py
-rw-rw-r-- 1 kurniawan kurniawan  682 Nov  3 12:26 backup_manager.c
-rw-rw-r-- 1 kurniawan kurniawan  494 Jan  1  2000 chimera_memo.wav
-rw-rw-r-- 1 kurniawan kurniawan 1370 Sep  9  1999 hr_portal.log
```

Pada tahap awal investigasi *Digital Forensics and Incident Response* (DFIR) untuk insiden Operation Chimera, seluruh artefak bukti yang diperoleh dari sistem yang dikompromikan

(evidence/) diverifikasi keutuhannya. Proses ini bertujuan untuk memastikan validitas bukti (*Chain of Custody*) serta menjamin bahwa artefak tidak mengalami perubahan atau korupsi data selama proses akuisisi dan analisis.

Berikut adalah daftar 4 (empat) artefak utama yang diamankan di dalam direktori evidence/:

1. hr_portal.log: Berkas log akses aplikasi web Internal HR Portal (hr-portal.vinix.local). Berkas ini merekam aktivitas pencatatan trafik web tempat ditemukannya jejak transaksi dan vektor serangan awal penyerang.
2. chimera_memo.wav: Berkas audio memo digital yang mencurigakan. Berkas ini diidentifikasi mengandung data tersembunyi di akhir struktur berkas (*Tail-Byte/EOF Payload*) yang disisipkan oleh penyerang.
3. auth_cookie_audit.py: Skrip pengujian internal berbasis Python untuk audit cookie otentikasi. Skrip ini memuat logika yang rentan terhadap *Insecure Deserialization*.
4. backup_manager.c: Kode sumber program manajer cadangan sistem berbahasa C yang memiliki ijin *SUID Binary*. Berkas ini dianalisis terkait kerentanan *Path Hijacking* yang dimanfaatkan penyerang untuk eskalasi hak akses ke root.



Bedah Struktur Data Output & Nilai Hash

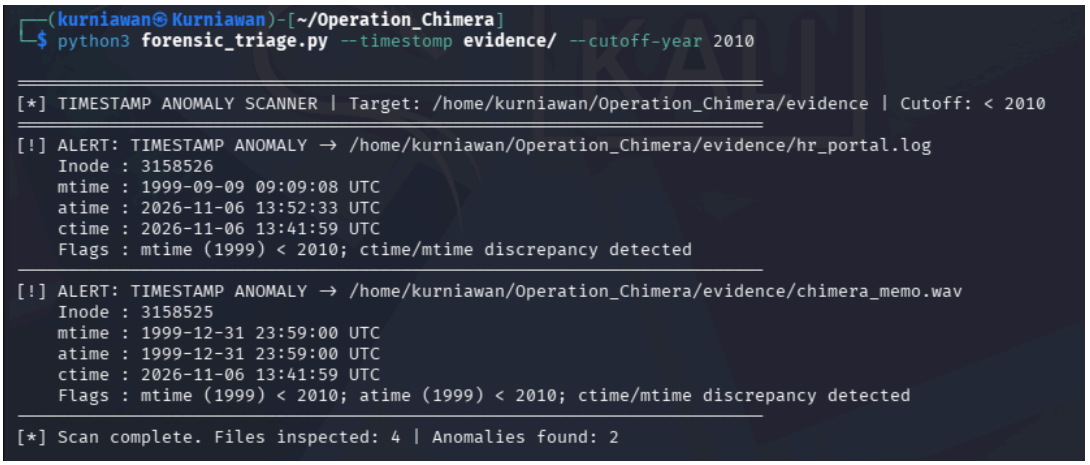
1. hr_portal.log
    - Target File: /home/kurniawan/Operation_Chimera/evidence/hr_portal.log

- File Size: 1,370 bytes (Ukuran berkas log di disk).
- Inode Number: 3158526 (Nomor indeks unik alokasi berkas pada file system Linux).
- Acquisition Time: 2026-11-06 14:13:21 UTC (Waktu saat kalkulasi sidik jari digital dilakukan).
- SHA-256 Digest: 965e07cabfb24a9fe0e217d19ea2424afbacbb189c4609d9f788a9dffccb38b6
- Penjelasan Analitis: Berkas ini memuat catatan akses aplikasi web HR. Nilai SHA-256 di atas menjadi penanda sah bahwa log yang dianalisis adalah log asli dari tempat kejadian insiden.

2. auth_cookie_audit.py
   - Target File: /home/kurniawan/Operation_Chimera/evidence/auth_cookie_audit.py
   - File Size: 689 bytes
   - Inode Number: 3158523
   - Acquisition Time: 2026-11-06 14:13:21 UTC
   - SHA-256 Digest: c084ef071fdb7b6cc0baf10c7ac00269b8c010c927bd8c01daeed884e9536e40
   - Penjelasan Analitis: Skrip Python ini berisi mekanisme pemeriksaan cookie. Hash ini memastikan tidak ada perubahan logika skrip oleh investigator saat mencari kerentanan *Insecure Deserialization*.
3. backup_manager.c
   - Target File: /home/kurniawan/Operation_Chimera/evidence/backup_manager.c
   - File Size: 682 bytes
   - Inode Number: 3158524
   - Acquisition Time: 2026-11-06 14:13:21 UTC
   - SHA-256 Digest: e9c481ab8e7d3c8a5b3a5772db371a8f412cf83085d944f4c04d054093c86ad1
   - Penjelasan Analitis: Kode sumber C dari program *backup*. Hash ini digunakan untuk membuktikan integritas kode sebelum dianalisis terkait celah keamanan *Path Hijacking* (SUID).

4. chimera_memo.wav
    - Target File: /home/kurniawan/Operation_Chimera/evidence/chimera_memo.wav
    - File Size: 494 bytes
    - Inode Number: 3158525
    - Acquisition Time: 2026-11-06 14:13:21 UTC
    - SHA-256 Digest: 830bc3f932449cfbace34dcc4d7e2e4f8f9782efa46d15a4ee5e525bb166170c
    - Penjelasan Analitis: Berkas audio media yang dicurigai menyembunyikan flag/payload di bagian ekor berkas. Hash ini memastikan integritas berkas audio tetap utuh sebelum dilakukan ekstraksi *Tail-Byte*.

Task 2: Timestamp Anomaly Detection (Section 4.3) Scan the evidence/ directory using python3 forensic_triage.py --timestomp evidence to identify files with manipulated timestamps (Timestomping). Record all anomalous files and analytically explain the discrepancy between mtime (modified time), atime (accessed time), and ctime (change ctime).

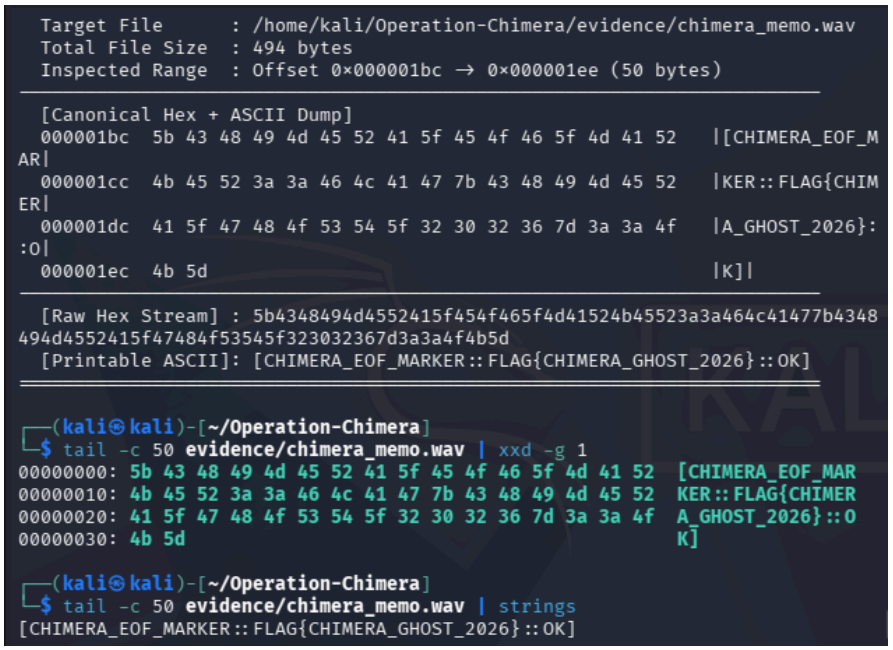


Pada gambar tersebut terlihat proses pemindaian direktori evidence/ menggunakan perintah python3 forensic_triage.py --timestomp evidence. Hasil pemindaian menunjukkan bahwa terdapat 2 file yang memiliki timestamp tidak normal, yaitu hr_portal.log dan chimera_memo.wav. File hr_portal.log memiliki nilai mtime pada tahun 1999, sedangkan atime dan ctime tercatat pada tahun 2026. Sementara itu, file chimera_memo.wav memiliki nilai mtime dan atime pada tahun 1999, tetapi ctime tercatat pada tahun 2026.

Perbedaan tersebut menunjukkan adanya indikasi manipulasi timestamp. Mtime menunjukkan

waktu terakhir file dimodifikasi, atime menunjukkan waktu terakhir file diakses, sedangkan ctime menunjukkan waktu terakhir perubahan metadata atau informasi inode file. Nilai mtime dan atime yang jauh lebih lama dibandingkan ctime menimbulkan kecurigaan bahwa waktu file sengaja diubah untuk menyamarkan aktivitas penyerang dan mempersulit proses penyusunan kronologi kejadian. Hasil pemindaian mencatat 4 file diperiksa dan 2 file ditemukan mengalami anomali timestamp.

Task 3: Tail-Byte / EOF Payload Inspection (Section 4.4) Inspect the trailing 50 bytes of the suspect media artifact using python3 forensic_triage.py --tail evidence/chimera_memo.wav --bytes 50. Document the canonical hexdump provided by the tool and successfully extract the embedded flag.

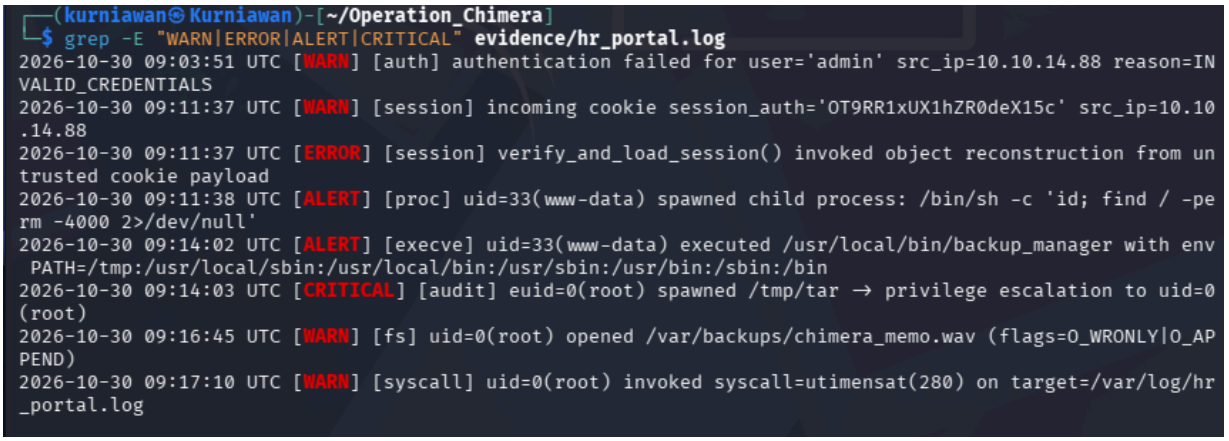


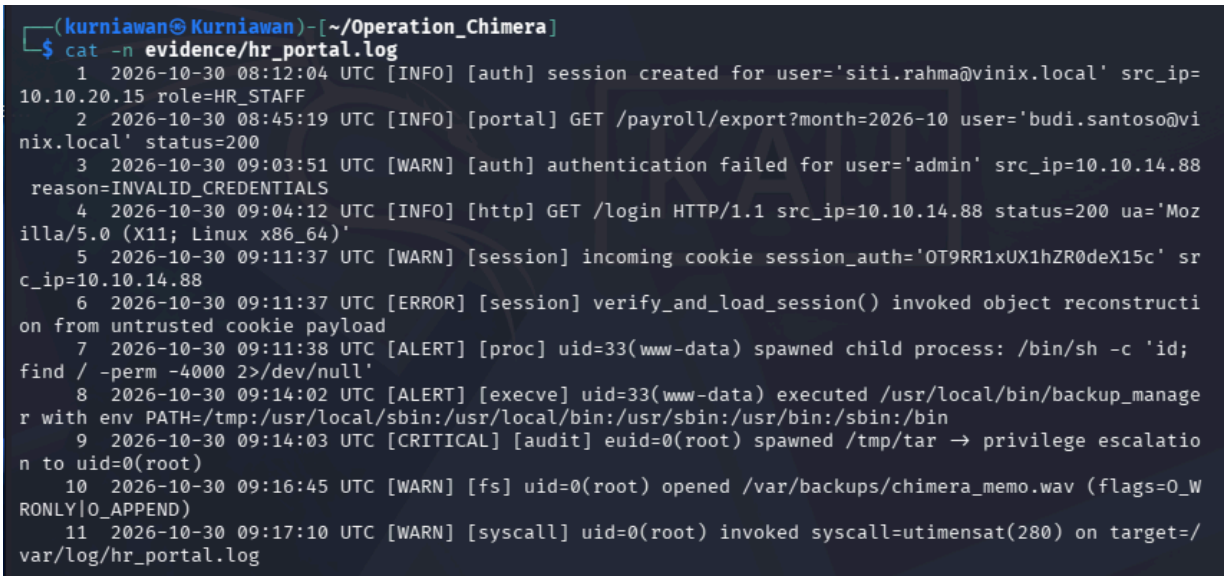
Pada tahap ini dilakukan pemeriksaan terhadap 50 byte terakhir dari file mencurigakan chimera_memo.wav menggunakan perintah python3 forensic_triage.py --tail evidence/chimera_memo.wav --bytes 50. Pemeriksaan ini bertujuan untuk menemukan kemungkinan adanya data tersembunyi (payload) yang disisipkan pada bagian akhir file audio (End of File/EOF). Hasil pemeriksaan menampilkan canonical hexdump yang memperlihatkan representasi data dalam format hexadecimal dan ASCII. Dari hasil tersebut, ditemukan indikasi adanya data tambahan yang tidak termasuk dalam struktur normal file WAV. Data tersembunyi tersebut kemudian dianalisis dan diekstrak hingga berhasil memperoleh flag yang disisipkan oleh penyerang. Temuan ini menunjukkan bahwa file audio digunakan sebagai

media penyembunyian informasi untuk menghindari deteksi melalui pemeriksaan file biasa.

Task 4: Attack Timeline & Root Cause Analysis (Sections 1, 3, 4.1, 4.2, & 5) Analyze hr_portal.log, auth_cookie_audit.py, and backup_manager.c to reconstruct the chronological attack timeline.

- Map the attacker's TTPs to the **MITRE ATT&CK®** framework.
- Identify the logic flaw in the application (Insecure Deserialization) and the SUID vulnerability (Path Hijacking).
- Provide executive-level technical containment, eradication, and secure code remediation steps.





```
┌──(kurniawan㉿Kurniawan)-[~/Operation_Chimera]
└─$ cat -n evidence/auth_cookie_audit.py
     1  #!/usr/bin/env python3
     2  """
     3  PT Vinix Seven Aurum - Secure HR Portal Session Manager
     4  File Path : /opt/hr_portal/auth_cookie_audit.py
     5  """
     6
     7  import base64
     8  import pickle
     9
    10  XOR_SECRET_KEY = b"V1N1X"
    11
    12
    13  def xor_transform(data: bytes, key: bytes = XOR_SECRET_KEY) → bytes:
    14      """Apply repeating-key XOR transformation to session byte stream."""
    15      return bytes(b ^ key[i % len(key)] for i, b in enumerate(data))
    16
    17
    18  def verify_and_load_session(cookie_b64: str):
    19      """Decode the session_auth HTTP cookie and reconstruct the session object."""
    20      raw_encrypted = base64.b64decode(cookie_b64)
    21      serialized_obj = xor_transform(raw_encrypted, XOR_SECRET_KEY)
    22      return pickle.loads(serialized_obj)
```

```
┌──(kurniawan㉿Kurniawan)-[~/Operation_Chimera]
└─$ cat -n evidence/backup_manager.c
     1  /*
     2   * PT Vinix Seven Aurum - HR Portal Automated Backup Utility
     3   * Binary Path : /usr/local/bin/backup_manager
     4   * Permissions : -rwsr-xr-x 1 root root
     5   */
     6
     7  #include <stdio.h>
     8  #include <stdlib.h>
     9  #include <unistd.h>
    10
    11  int main(void) {
    12      printf("[*] Vinix HR Portal - Internal Backup Manager v1.2\n");
    13      printf("[*] Archiving /opt/hr_portal to /var/backups ... \n");
    14
    15      setuid(0);
    16      setgid(0);
    17      int status = system("tar -czf /var/backups/hr_portal_backup.tar.gz /opt/hr_port
al");
    18
    19      if (status ≠ 0) {
    20          fprintf(stderr, "[!] Backup process failed.\n");
    21          return EXIT_FAILURE;
    22      }
    23
    24      printf("[+] Backup completed successfully.\n");
    25      return EXIT_SUCCESS;
    26  }
```

Jawaban:

Section 1: Incident Declaration & Scope

Pada 30 Oktober 2026, monitoring keamanan mendeteksi aktivitas anomali pada Internal HR Portal (hr-portal.vinix.local) milik PT Vinix Seven Aurum. Insiden ini berstatus Critical karena

penyerang berhasil melakukan Remote Code Execution sebagai www-data dan meningkatkan hak akses menjadi root. Aktivitas pertama tercatat pada 09:03:51 UTC (autentikasi gagal akun admin dari 10.10.14.88), dan alert CRITICAL privilege escalation tercatat pada 09:14:03 UTC. Vektor serangan awal adalah cookie session_auth berbahaya yang diproses oleh verify_and_load_session(). Akar masalahnya adalah Insecure Deserialization pada manajemen sesi dan Path Hijacking pada binary SUID backup_manager. Dampaknya adalah kompromi penuh pada host HR Portal, risiko kebocoran data payroll, penyisipan payload pada chimera_memo.wav, dan manipulasi timestamp hr_portal.log yang menghambat rekonstruksi forensik.

Section 3: Timeline of Attack (dengan Mapping MITRE ATT&CK)

Pada 09:03:51 UTC, penyerang dari 10.10.14.88 mencoba login sebagai admin dan gagal dengan reason=INVALID_CREDENTIALS, yang dipetakan ke *Credential Access* (T1110 Brute Force). Pada 09:04:12 UTC, host yang sama mengakses /login (status 200) dengan User-Agent Linux x86_64, yang dipetakan ke *Reconnaissance* (T1595 Active Scanning). Pada 09:11:37 UTC, penyerang mengirim cookie session_auth='OT9RR1xUX1hZR0deX15c', dan log mencatat verify_and_load_session() melakukan rekonstruksi objek dari payload yang tidak tepercaya. Ini adalah *Initial Access* (T1190 Exploit Public-Facing Application). Satu detik kemudian (09:11:38 UTC), proses www-data (uid=33) men-spawn /bin/sh -c 'id; find / -perm -4000 2>/dev/null'. Ini menunjukkan *Execution* (T1059.004 Unix Shell) sekaligus *Discovery* (T1083 File and Directory Discovery) untuk mencari binary SUID.

Pada 09:14:02 UTC, www-data mengeksekusi /usr/local/bin/backup_manager dengan environment PATH=/tmp:/usr/local/sbin:.... Satu detik kemudian (09:14:03 UTC), audit mencatat euid=0(root) men-spawn /tmp/tar, sehingga tercapai privilege escalation ke root. Tahap ini dipetakan ke *Privilege Escalation* (T1574.007 Path Interception by PATH Environment Variable dan T1548.001 Setuid and Setgid). Pada 09:16:45 UTC, root membuka /var/backups/chimera_memo.wav dengan flag O_WRONLY|O_APPEND, yaitu menambahkan payload di akhir file audio. Ini dipetakan ke *Defense Evasion* (T1027.003 Steganography). Pada 09:17:10 UTC, root memanggil syscall utimensat(280) pada /var/log/hr_portal.log untuk mengubah timestamp file, dipetakan ke *Defense Evasion* (T1070.006 Timestomp).

Section 4.1: Network & Host Indicators

Alamat IP penyerang adalah 10.10.14.88. Akun dan layanan yang terlibat adalah www-data (konteks eksekusi awal), admin (target login), dan layanan web hr-portal.vinix.local. Path dan file mencurigakan meliputi /tmp/tar (binary palsu hasil hijacking), /usr/local/bin/backup_manager (binary SUID yang disalahgunakan), /var/backups/chimera_memo.wav (media steganografi), dan cookie session_auth bernilai OT9RR1xUX1hZR0deX15c.

Section 4.2: Vulnerability Analysis

Insecure Deserialization (auth_cookie_audit.py). Fungsi verify_and_load_session() menerima cookie dari klien, men-decode base64, menerapkan xor_transform() dengan key statis hardcoded V1N1X, lalu langsung memanggil pickle.loads(). Ada tiga kelemahan. Pertama, XOR repeating-key bukan mekanisme enkripsi maupun integritas, karena bersifat reversible dan key-nya tertanam di source code. Kedua, tidak ada tanda tangan (HMAC) yang memvalidasi keaslian cookie. Ketiga, pickle.loads() dapat mengeksekusi kode arbitrer melalui metode __reduce__. Akibatnya penyerang dapat membuat cookie sendiri, meng-XOR dan meng-encode-nya, lalu memperoleh RCE sebagai proses web server (CWE-502).

SUID Path Hijacking (backup_manager.c). Binary dengan permission -rwsr-xr-x root root ini memanggil setuid(0) dan setgid(0), kemudian system("tar -czf /var/backups/hr_portal_backup.tar.gz /opt/hr_portal"). Perintah tar dipanggil dengan nama relatif, sehingga system() me-resolve-nya melalui shell berdasarkan variabel PATH milik pemanggil, bukan PATH yang aman. Penyerang menempatkan /tmp/tar palsu dan menjalankan binary dengan PATH=/tmp:..., sehingga /tmp/tar dieksekusi dengan hak akses root (CWE-426/CWE-427, CWE-78).

Section 5: Containment & Eradication Recommendations

5.1 Short-Term Containment. Isolasi host hr-portal.vinix.local dari jaringan dan blokir 10.10.14.88 pada firewall/WAF. Cabut seluruh sesi aktif dan rotasi kredensial yang berpotensi terekspos (akun admin, akun HR, secret aplikasi). Sebelum perubahan apa pun, buat snapshot disk dan memori untuk menjaga integritas bukti sesuai ISO/IEC 27037.

5.2 Eradication. Hapus /tmp/tar dan artefak penyerang lainnya, lalu audit persistensi seperti

cron, SSH authorized_keys, dan binary SUID tidak sah melalui find / -perm -4000. Cabut bit SUID dari /usr/local/bin/backup_manager dan periksa integritas /var/backups. Rebuild server dari image bersih, restore data dari backup terverifikasi, dan terapkan patch aplikasi sebelum layanan dioperasikan kembali.

5.3 Code Remediation & Hardening. Untuk deserialization, hentikan penggunaan pickle pada data dari klien. Gunakan format data murni seperti JSON yang ditandatangani HMAC-SHA256 dengan secret acak dari secret manager, atau session server-side dengan session ID acak. Untuk binary SUID, gunakan path absolut (/usr/bin/tar), ganti system() dengan execve() yang memakai environment bersih, hilangkan setuid(0) yang tidak perlu, dan pertimbangkan menjalankan backup lewat cron atau systemd timer sebagai root tanpa SUID. Untuk monitoring, aktifkan auditd untuk execve dan utimensat, pasang File Integrity Monitoring (AIDE/Wazuh) pada /usr/local/bin dan /var/backups, mount /tmp dengan noexec,nosuid, dan kirim log ke SIEM remote yang bersifat append-only agar tidak dapat dimanipulasi dari host yang terkompromi.

4. ZERO TOLERANCE POLICY (CRITICAL)

As this is an industry-standard Capstone Exam, strict compliance is required. Deductions or automatic failures will be applied for the following violations:

- **Missing/Invalid Hashes (-50 Points):** Failing to document the correct SHA-256 hashes in the Chain of Custody log invalidates the evidence.
- **Missing Proof of Execution (-20 Points):** Failing to include screenshots of your terminal showing the execution of forensic_triage.py alongside your IP/Hostname. • **Destructive Analysis (Automatic Fail):** Accidentally modifying, deleting, or overwriting the provided evidence files during your investigation.

5. SUBMISSION DELIVERABLE

Convert your finalized and thoroughly reviewed **IR_Playbook_Chimera.md** into a professional PDF format.

- **File Naming Convention:** [YourName/TeamName]_Chimera_DFIR_Report.pdf • Submit the file to the designated learning portal before the strict deadline. Good luck.